

Amazon S3 Bucket Policy

To Begin with the Lab

Summary of the Lab

In this lab, **Amazon S3 Bucket Policies** were used to control access to S3 buckets directly from the bucket side instead of attaching permissions to an IAM user. Three separate buckets were prepared for **read-only**, **write-only**, and **full access** testing, along with one IAM user created with no permissions at first. The lab showed how a bucket policy must include the **Principal** field to specify the IAM user or role that should get access, and how the same S3 actions can be granted differently depending on the bucket. It also showed that when using the AWS Console, the user needs a small IAM permission like `s3:ListAllMyBuckets` just to see the bucket list, while the actual bucket access comes from the bucket policy itself.

Understanding S3 Bucket Policies

An **S3 Bucket Policy** is a **resource-based policy** attached directly to the bucket. It exists so you can give access to a specific IAM user, group, or role without attaching the permission to that identity. Unlike IAM policies, bucket policies must include a **Principal** section that says who is allowed or denied. This makes bucket policies useful when you want the permission to live with the bucket itself rather than with the user.

Example:

A bucket policy can allow one IAM user to read objects from read-only-bucket-folks, another policy can allow only uploads to write-only-bucket-folks, and a third policy can allow all actions on full-access-bucket-folks. The sample policies in the lab show exactly this separation using `s3:GetObject`, `s3:PutObject`, and `s3:*`.

Lab Steps

Step 1 – Prepare the test resources

- Create three buckets: **Read-Only Bucket**, **Write-Only Bucket**, and **Full Access Bucket**.

Amazon S3 > Buckets

Buckets

General purpose buckets (253) [Info](#) [Copy ARN](#) [Empty](#) [Delete](#) [Create bucket](#)

Buckets are containers for data stored in S3.

Search: cloudfre 3 matches

	Name	AWS Region	Creation date
☐	cloudfreeks-full-access	US East (N. Virginia) us-east-1	July 20, 2026, 15:18:58 (UTC+05:30)
☐	cloudfreeks-read-only	US East (N. Virginia) us-east-1	July 20, 2026, 15:18:23 (UTC+05:30)
☐	cloudfreeks-write-only	US East (N. Virginia) us-east-1	July 20, 2026, 15:18:38 (UTC+05:30)

Account snapshot [Info](#) [View dashboard](#)
Updated daily
Storage Lens provides visibility into storage usage and activity trends.

External access summary [Info](#)
Updated daily
External access findings help you identify bucket permissions that allow public access or access from other AWS accounts.

- Upload the sample file sample_file.txt into the buckets for testing.

Amazon S3

Upload: status [Close](#)

After you navigate away from this page, the following information is no longer available.

Summary

Destination: s3://cloudfreeks-write-only

Succeeded
1 file, 29.0 B (100.00%)

Failed
0 files, 0 B (0%)

Files and folders [Configuration](#)

Files and folders (1 total, 29.0 B)

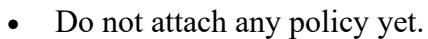
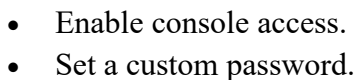
Find by name

Name	Folder	Type	Size	Status	Error
sample_file.txt	-	text/plain	29.0 B	Succeeded	-

- Confirm that no bucket policy is attached at the start.

Step 2 – Create an IAM user

- Open IAM → Users.
- Create a new user named S3User.



- Do not attach any policy yet.

Review and create

Review your choices. After you create the user, you can view and download the autogenerated password, if enabled.

User details

User name: S3User

Console password type: Custom password

Require password reset: No

Permissions summary

No resources

Tags - optional

Tags are key-value pairs you can add to AWS resources to help identify, organize, or search for resources. Choose any tags you want to associate with this user.

No tags associated with the resource.

[Add new tag](#)

You can add up to 50 more tags.

[Cancel](#) [Previous](#) [Create user](#)

- Sign in using the new IAM user and confirm that it cannot access S3.

Service menu

You can access all AWS services here. There are sections for recently visited and you can save your favorite services too.

[Next](#) [US Regions](#) [Directory buckets](#)

General purpose buckets (0) [info](#)

[Copy ARN](#) [Empty](#) [Delete](#) [Create bucket](#)

Buckets are containers for data stored in S3.

[Find buckets by name](#)

You don't have permissions to list buckets

After you or your AWS administrator has updated your permissions to allow the `s3:ListAllMyBuckets` action, refresh this page. Learn more about [identity and access management in Amazon S3](#).

[Diagnose with Amazon Q](#)

Account snapshot [info](#)

[Updated daily](#)

[View dashboard](#)

Storage Lens provides visibility into storage usage and activity trends.

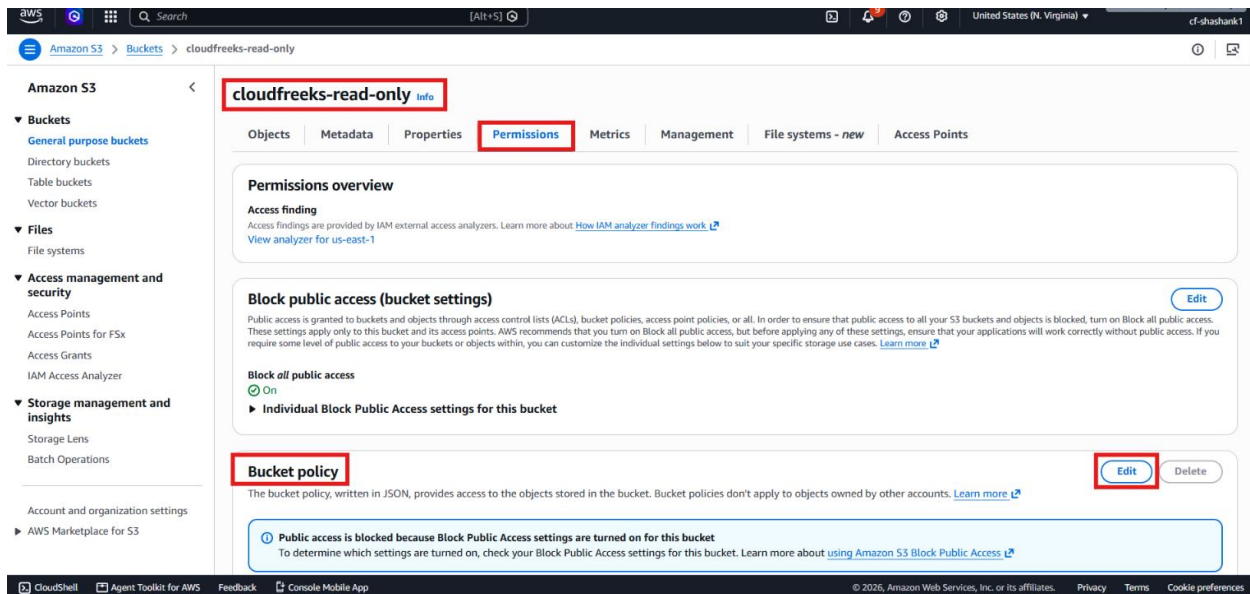
External access summary [info](#)

[Updated daily](#)

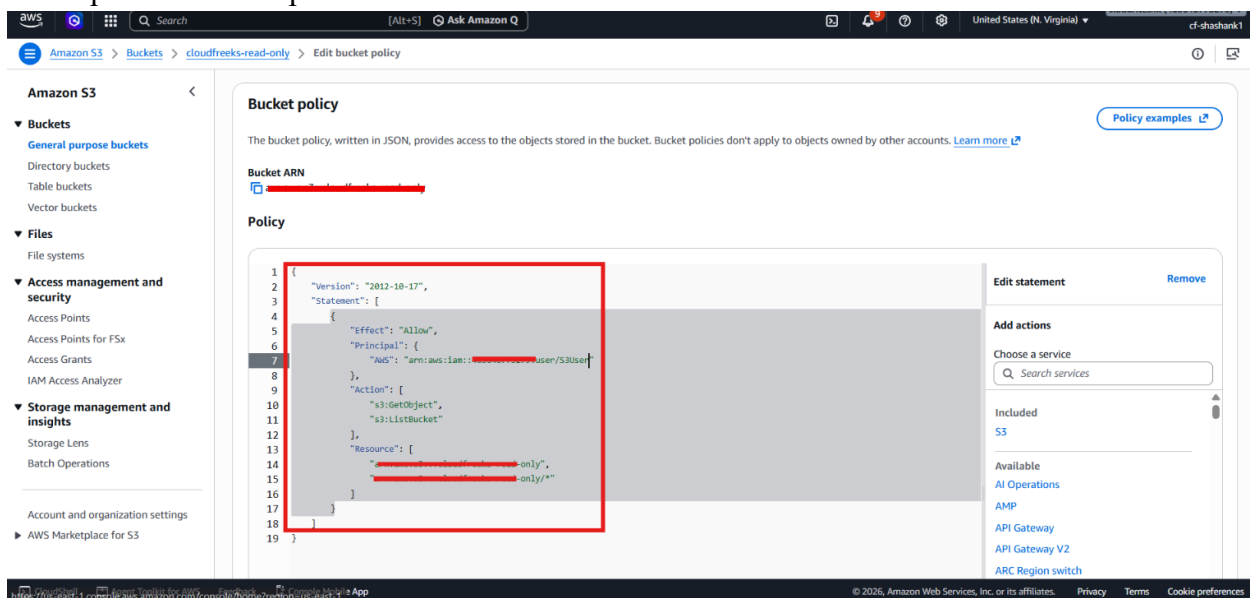
External access findings help you identify bucket permissions that allow public access or access from other AWS accounts.

Step 3 – Apply the Read-Only bucket policy

- Open the **Read-Only Bucket**.
- Go to **Permissions** and edit the **Bucket Policy**.



- Paste the read-only policy.
- Replace the Principal ARN with the IAM user ARN.

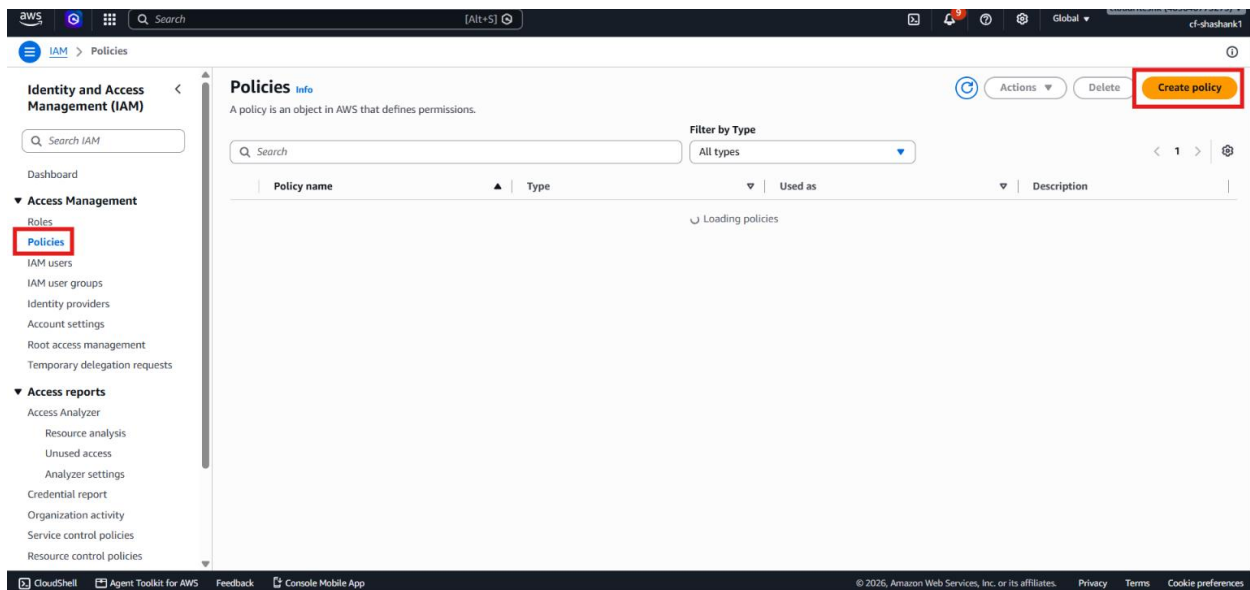


- Save the changes.

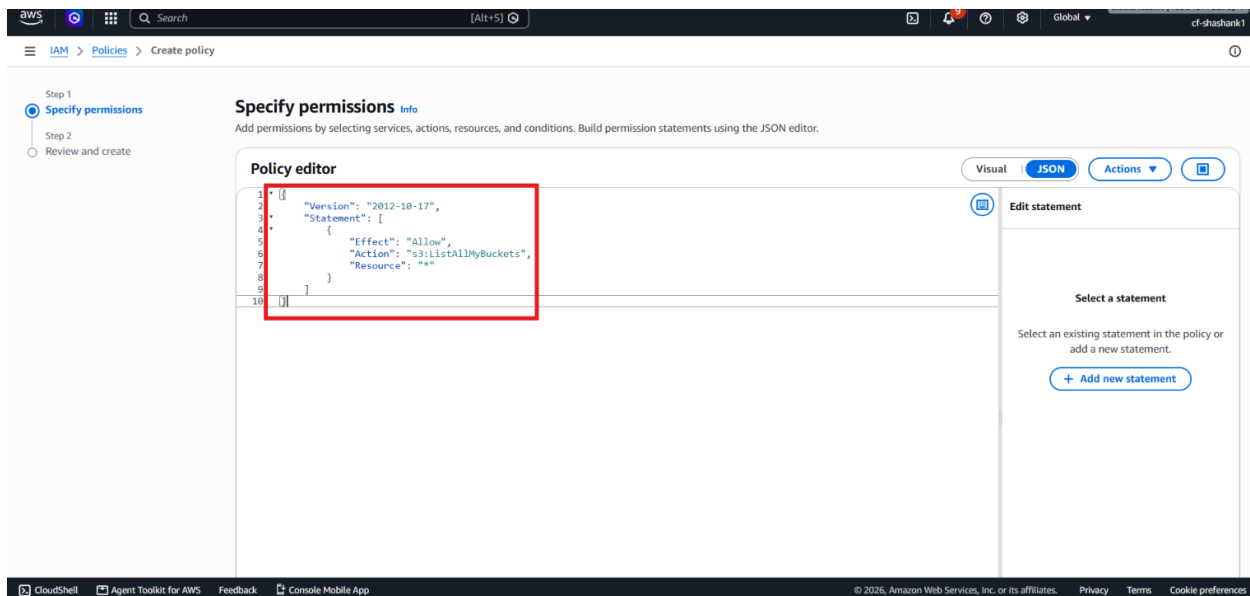
The read-only bucket policy allows s3:GetObject and s3:ListBucket for the specific IAM user.

Step 4 – Create IAM Policy and attach it

- Open IAM → Policies
- Create a new Customer Managed Policy



- Use the JSON editor
- Configure permissions to:
 - List all S3 buckets



- Create the policy and set the required name for policy.

Step 1: Specify permissions
Step 2: **Review and create**

Review and create

Review the permissions, specify details, and tags.

Policy details

Policy name
Enter a meaningful name to identify this policy.

Console-access-s3

Maximum 128 characters. Use alphanumeric and "+,=, @, _" characters.

Description - optional
Add a short explanation for this policy.

Maximum 1,000 characters. Use alphanumeric and "+,=, @, _" characters.

Permissions defined in this policy

Permissions defined in this policy document specify which actions are allowed or denied. To define permissions for an IAM identity (user, user group, or role), attach a policy to it

Search

Allow (1 of 472 services) Show remaining 471 services

Service	Access level	Resource	Request condition
S3	Limited: List	All resources	None

- Attach the policy to the IAM user by opening user and clicking on **Add Permissions**.

Identity and Access Management (IAM)

Search IAM

Dashboard

Access Management

- Roles
- Policies
- IAM users**
- IAM user groups
- Identity providers
- Account settings
- Root access management
- Temporary delegation requests

Access reports

- Access Analyzer
 - Resource analysis
 - Unused access
 - Analyzer settings
- Credential report
- Organization activity
- Service control policies
- Resource control policies

S3User

Summary

ARN: [arn:aws:iam::123456789012:user/S3User](#)

Created: July 20, 2026, 13:15 (UTC+05:30)

Console access: Enabled without MFA

Last console sign-in: Today

Access key 1: [Create access key](#)

Permissions | Groups | Tags | Security credentials | Last Accessed

Permissions policies (0)

Permissions are defined by policies attached to the user directly or through groups.

Search

Filter by Type: All types

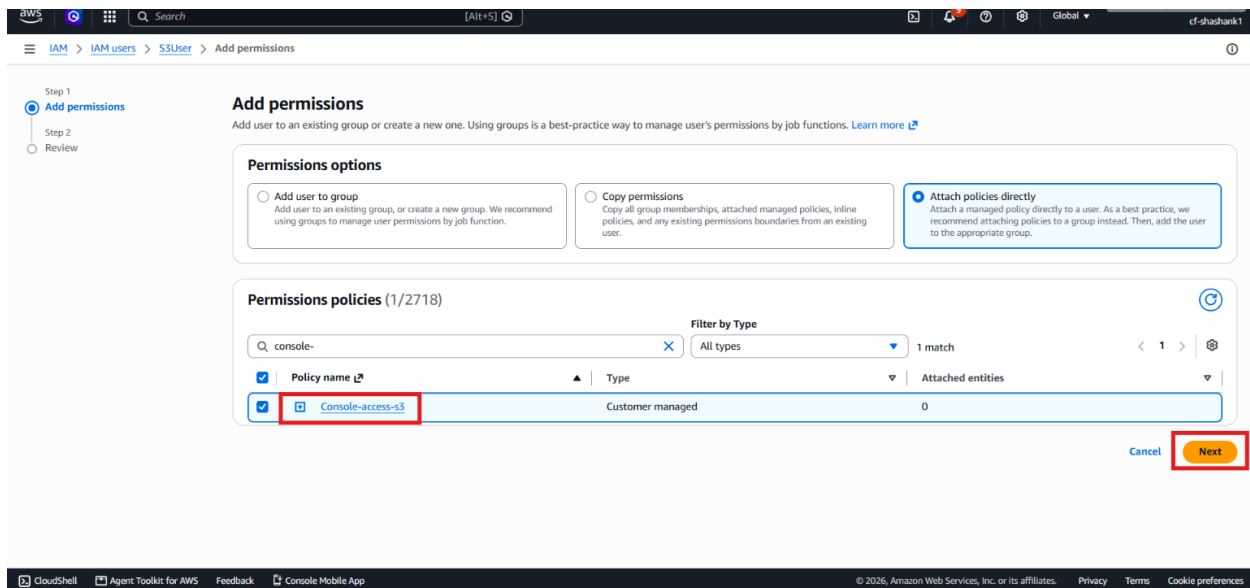
Policy name	Type	Attached via
No resources to display		

Permissions boundary (not set)

Add permissions

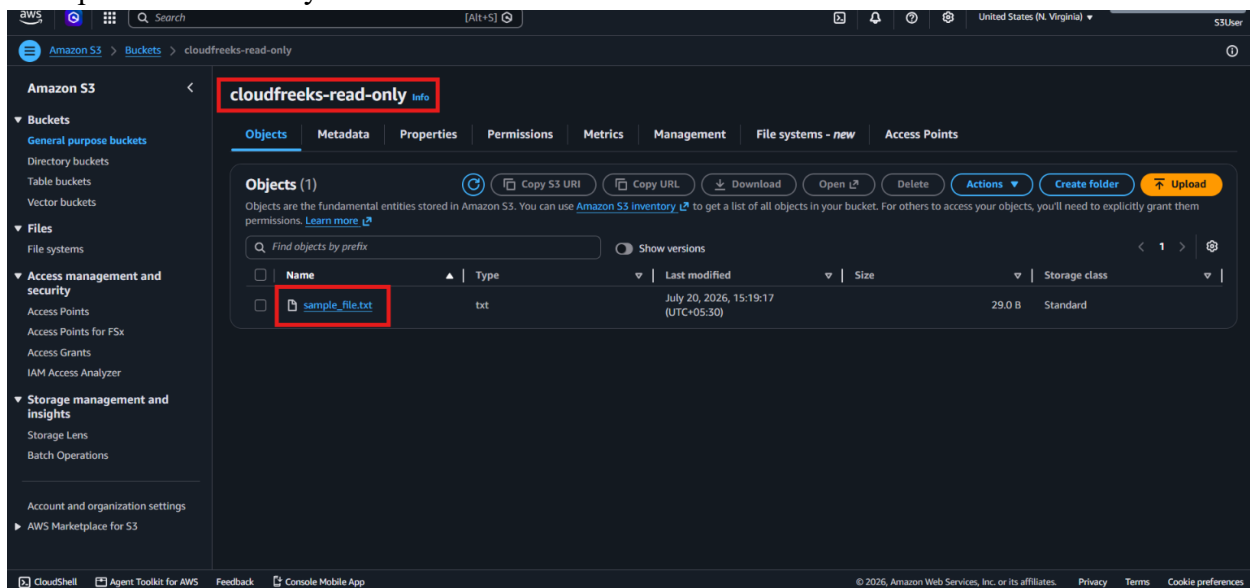
- Add permissions
- Create inline policy

- Now attach the policy we have just created.

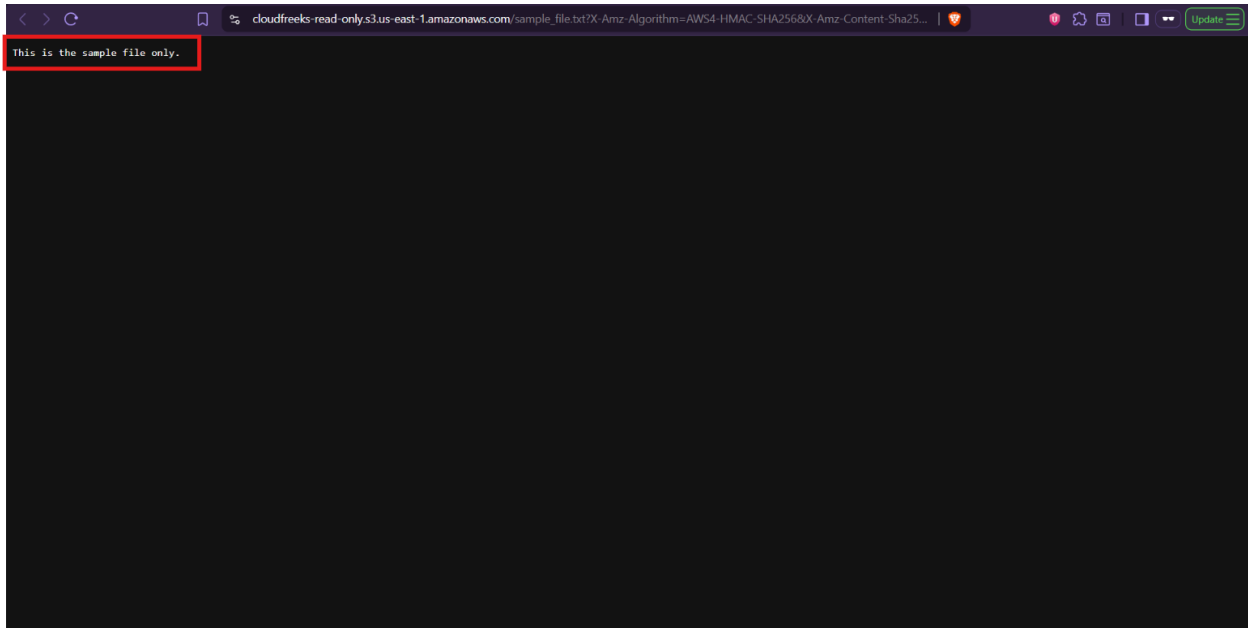


Step 5 – Test the Read-Only bucket

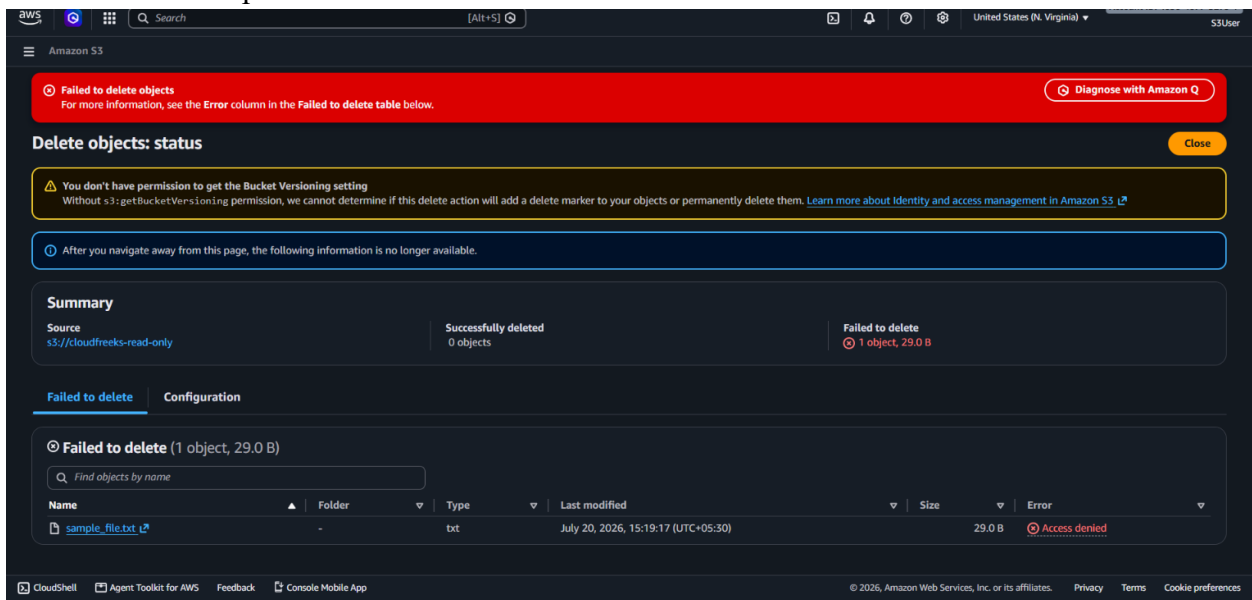
- Log in as S3User.
- Open the Read-Only Bucket.



- Confirm that objects can be viewed and opened.

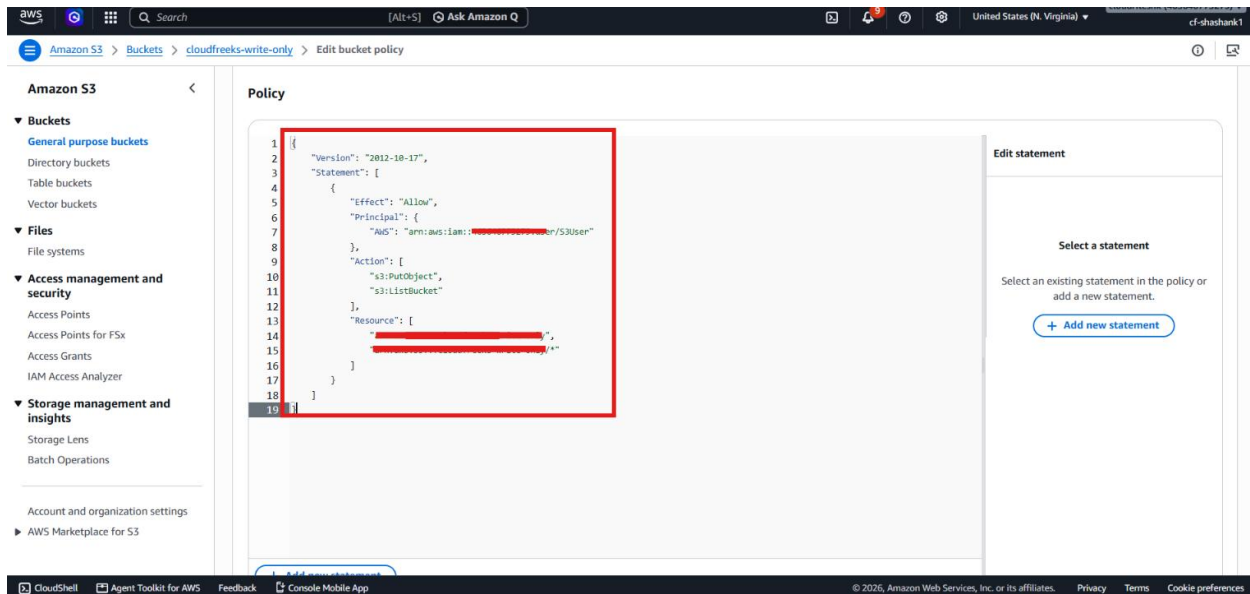


- Confirm that upload and delete actions fail.



Step 6 – Apply the Write-Only bucket policy

- Open the **Write-Only Bucket**.
- Replace the bucket policy with the write-only policy.

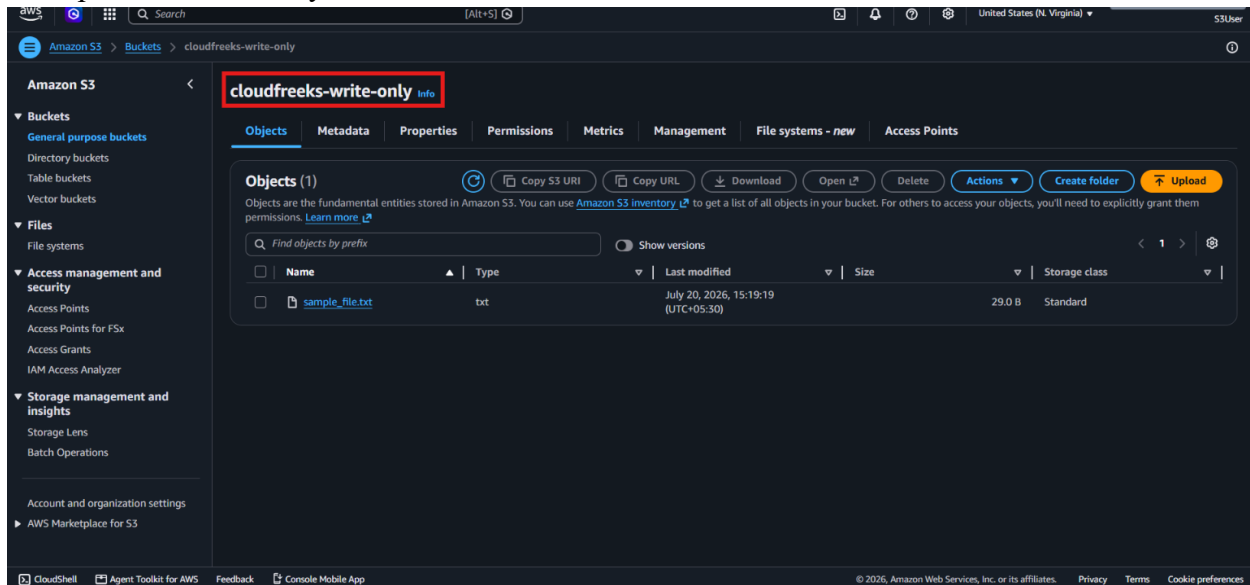


- Keep the IAM user ARN in the Principal section.
- Save the changes.

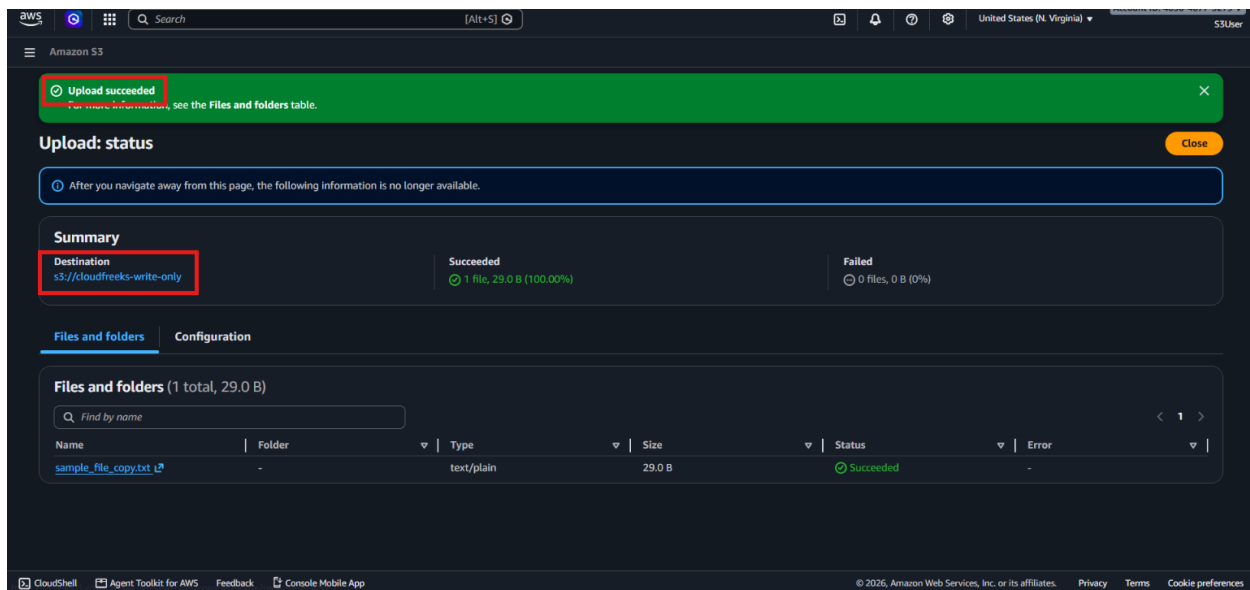
The write-only bucket policy allows s3:PutObject and s3:ListBucket.

Step 7 – Test the Write-Only bucket

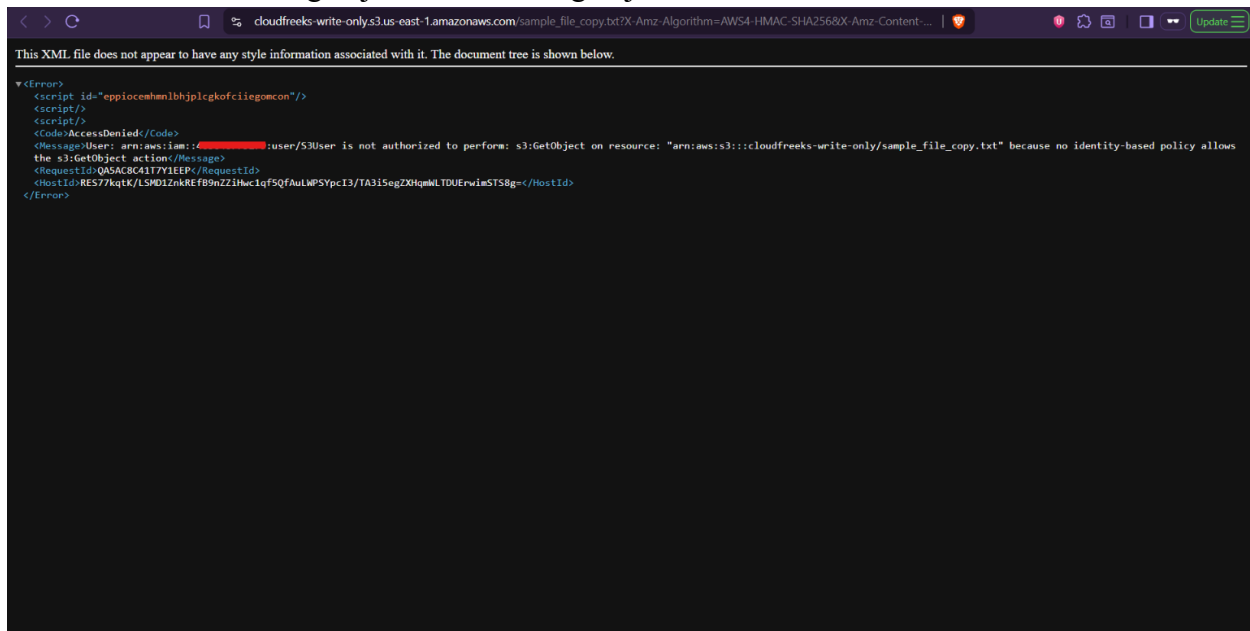
- Log in as S3User.
- Open the Write-Only Bucket.



- Confirm that uploads work.

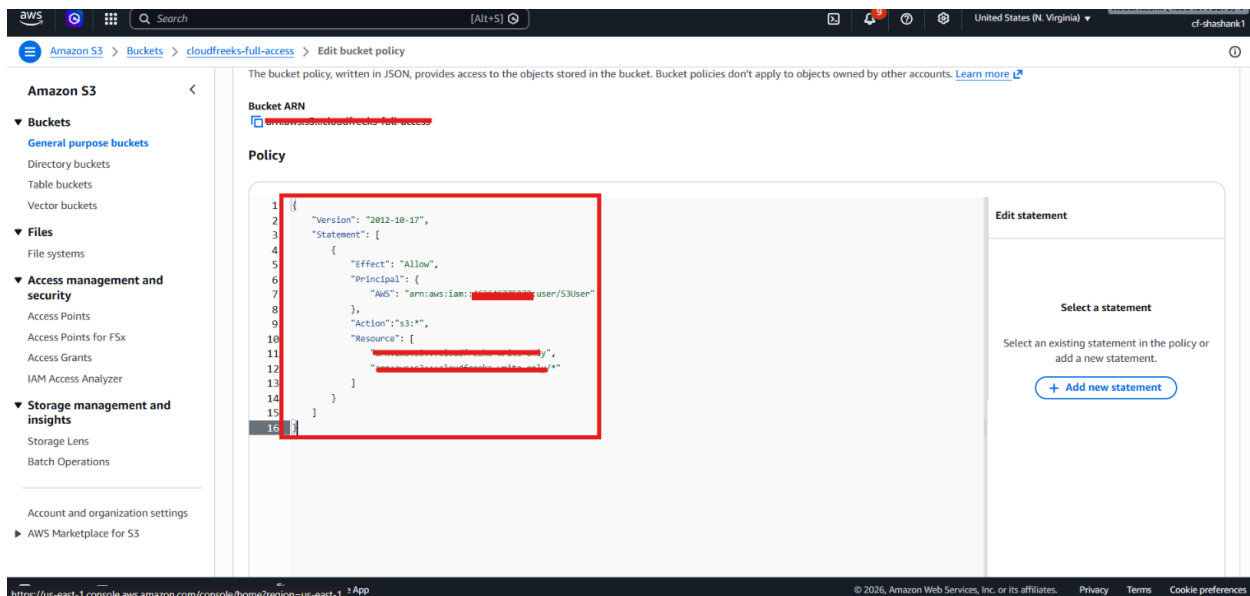


- Confirm that reading objects and deleting objects fail.



Step 8 – Apply the Full Access bucket policy

- Open the **Full Access Bucket**.
- Edit the bucket policy.
- Paste the full access policy.

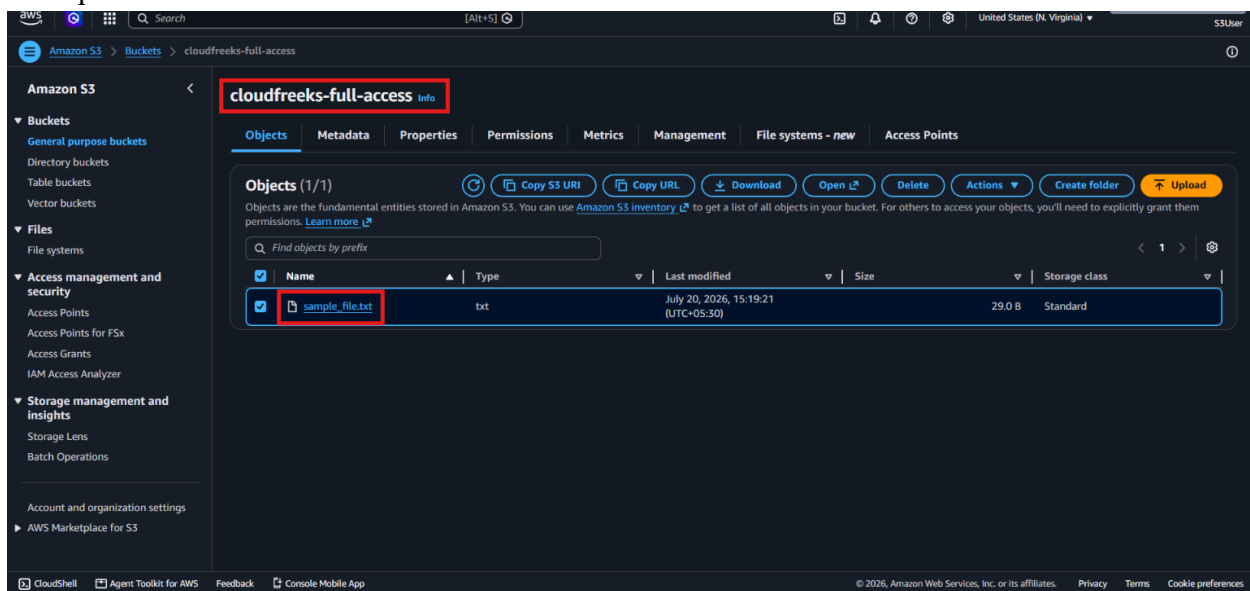


- Save the changes.

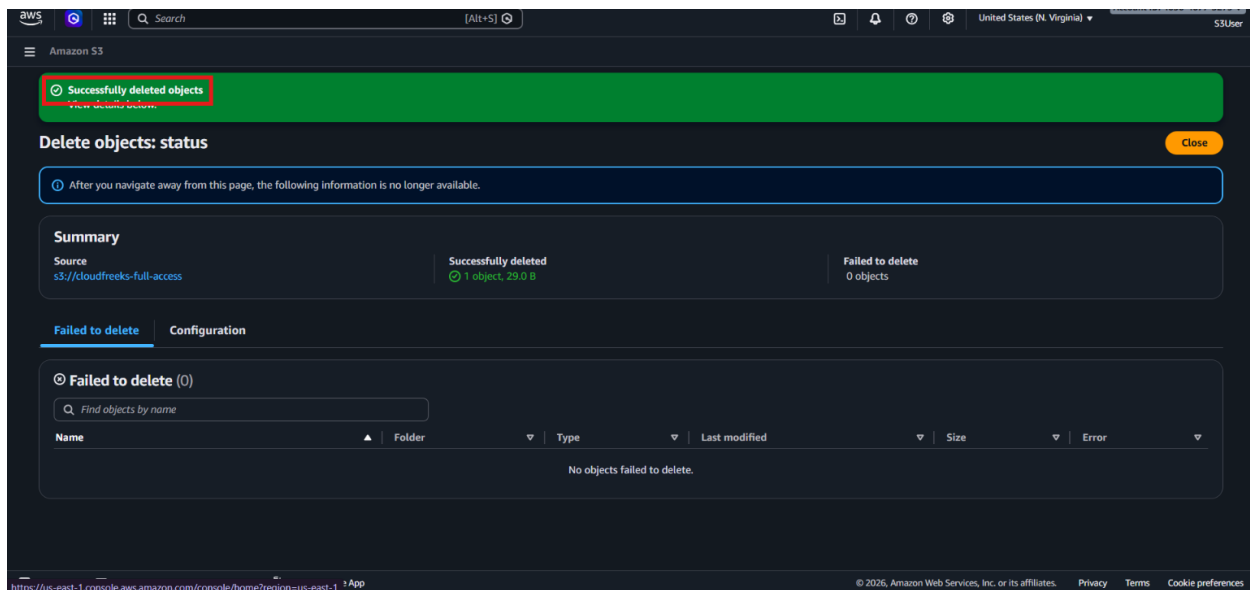
The full access bucket policy allows s3:* for the specified IAM user.

Step 9 – Test the Full Access bucket

- Log in as S3User.
- Open the Full Access Bucket.



- Confirm that read, upload, and delete operations all work successfully.



Verification

- Verified that a user with no permissions cannot access S3.
- Verified that the Read-Only Bucket Policy allows reading objects only.
- Verified that the Write-Only Bucket Policy allows uploads only.
- Verified that the Full Access Bucket Policy allows all S3 actions.
- Verified that bucket policies use the **Principal** field to name the IAM user.
- Verified that s3:ListAllMyBuckets is needed only for AWS Console bucket listing.